

[Open in app](#)**Medium**

Her şeye erişim. Şimdi %30 indirim. [Upgrade now](#)

Kimlik Avı Analizi +

10 dakikalık okuma süresi · Şu anda



Nuh hozar



Listen



Share

... More

[← Back to all walkthroughs](#)



Phishing Analysis Fundamentals

Learn all the components that make up an email.

  30 min  185,108 

 Start AttackBox

 Save Room

 2577 Recommend

 Connectivity

 Options

Kimlik Avı Analizi Temelleri “TRYHACKME ADIM ADIM KILAVUZU”



Phishing Analysis Fundamentals

Task 1- Introduction

Spam and Phishing remain the most common social engineering threats facing modern organizations. While spam is often low-risk, phishing can trick users into disclosing sensitive information or unknowingly deploying malware. A single unsuspecting user who clicks a malicious link or opens an attachment can give an attacker an initial foothold in the network and cause huge damage to the company.

As a defender, your role involves analyzing email components to determine if they are malicious or benign and gathering information to help harden security measures against future attacks. In this task, you will inspect raw email files and

learn how to identify the true origin and intent of a suspicious message.

Learning Objectives

- Learn the basics of email delivery
- Explore email header analysis
- Investigate and analyze email bodies
- Learn about the different types of phishing
- Analyze emails to identify potential security threats

Task 2- The Email Address

Every phishing email you'll investigate starts with something simple: an email address. If you don't understand how it's structured, you may overlook the very clues attackers rely on. Email as we know it today was popularized in the 1970s on ARPANET by Ray Tomlinson, who introduced the @ symbol to separate the user from the destination system.

Anatomy of an Email Address

So what makes up an email address? Let's take a look at the example below, where an email is composed of the following elements:

1. Username: User mailbox that identifies the specific recipient's mailbox on the email server
2. @ symbol: Separates the username from the domain and tells the system where to route the email
3. Domain name: Specifies the mail server responsible for receiving the message

In the last example, the intended recipient username is `david` and the intended recipient domain is `tryhackme.com`.



A helpful analogy is to think of an email address as a home mailing address:

- The **domain** is like the street or apartment building
- The **username** is the specific person or mailbox within that location

With both pieces of information, the postal worker (mail server) knows exactly where to deliver the message. In the next task, we'll explore the network protocols responsible for sending and receiving emails.

Answer the questions below

Q 1- Identify the domain used in the following email address:

hatsalesman@tryhatme.com

Answer: tryhatme.com

Task 3- Email Delivery

When you send an email, several protocols work together behind the scenes to deliver your message from sender to recipient, and each protocol has a specific role:

- **Simple Mail Transfer Protocol (SMTP):** Sends emails
- **Post Office Protocol (POP3):** Downloads emails to a device

- **Internet Message Access Protocol (IMAP):** Syncs emails across devices

When receiving emails, your email service will use either POP3 or IMAP, depending on how your mailbox is configured. Let's take a look at both of these protocols below:

POP3

- Emails are downloaded and stored on a single device
- Sent messages are stored on the single device from which the email was sent
- Emails can only be accessed from the single device to which the emails were sent
- Emails are typically removed from the server after download

IMAP

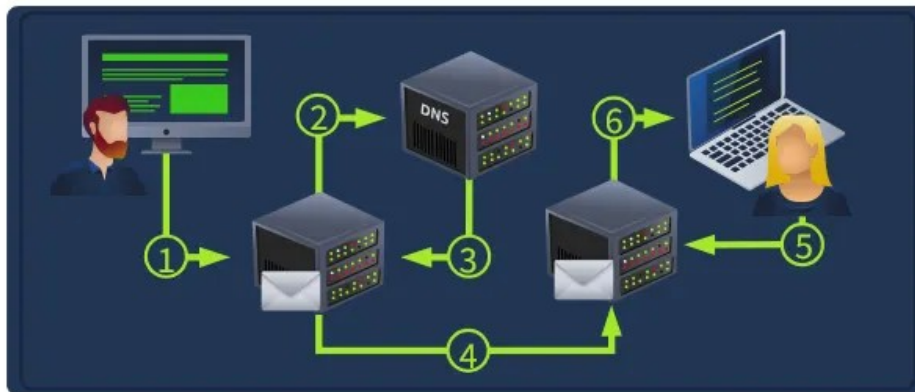
- Emails are stored on the server and can be downloaded to multiple devices
- Sent messages are stored on the server
- Syncs messages across multiple devices
- Emails remain on the server unless explicitly deleted

An Email's Journey

Rather than memorizing definitions, it's easier to understand these protocols by following the path an email takes. Let's take a look at a simplified flow through of the journey an email takes from sender to receiver:

1. User sends an email: The sender's email client sends the message to their mail server using SMTP
2. Mail server queries DNS: The sending server asks DNS for the recipient domain's mail server
3. DNS responds: DNS returns the address of the recipient's mail server
4. Email is delivered: The message is sent across the Internet to the recipient's server

5. The recipient checks their mailbox: The recipient's email client connects to their mail server
6. Email is retrieved: The message is downloaded (POP3) or synced (IMAP) to the recipient's device



Answer the questions below

Q 2-Which protocol is responsible for sending an email from a client to a mail server?

Answer : SMTP

Q 3- Which service is used to look up the recipient domain's mail server?

Answer : DNS

Q 4- Bob wants to access his email from multiple devices, including his phone and laptop.

Which protocol should he use?

Answer : IMAP

Task 4- Email Headers

Now that you understand how an email travels from sender to recipient, let's take a closer look at what an email actually contains when it arrives in an inbox. This is especially important when analyzing potentially malicious emails.

An email consists of two main parts:

- **Email header:** Contains metadata about the message, such as sender and the servers involved in delivery
- **Email body:** Contains the actual message content, which may be plain text or HTML

Email Headers

Let's take a look at the different components that make up an email header. In your VM, open up the `email1.eml` file in the `Email Samples` folder on your desktop.

1. **From:** The sender's email address
2. **To:** The receiver's email address
3. **Reply to:** Address where replies are sent (not required)
4. **Subject:** The email's subject line
5. **Date:** The time and date that the email was sent

Viewing the Message Source

Another method to obtain the same email header information, and more, is by viewing the raw message data. Viewing the email source displays the full raw message, including all header fields and the email body, which may contain plain text or HTML. It also reveals technical details not visible in the standard inbox view.

Ensure you're viewing the `email1.eml` sample in Thunderbird mail in your VM instance:

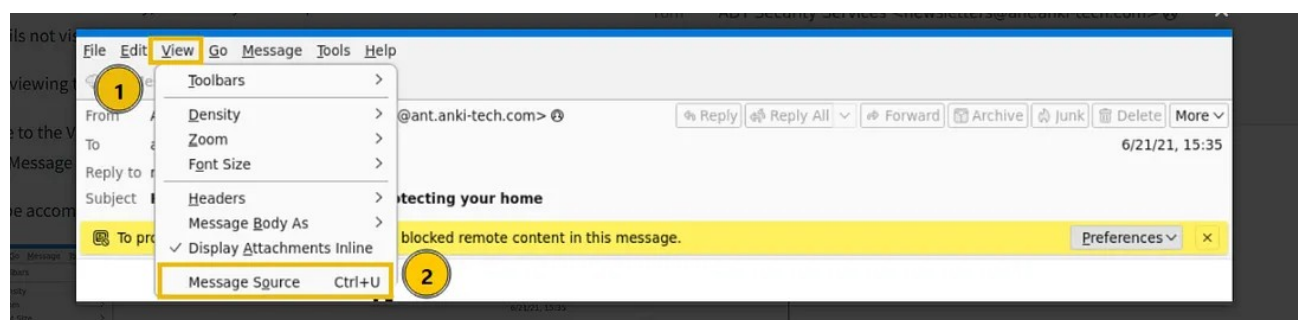
1. Navigate to the View menu
2. Choose Message Source

This can also be accomplished with the shortcut `ctrl + u`.

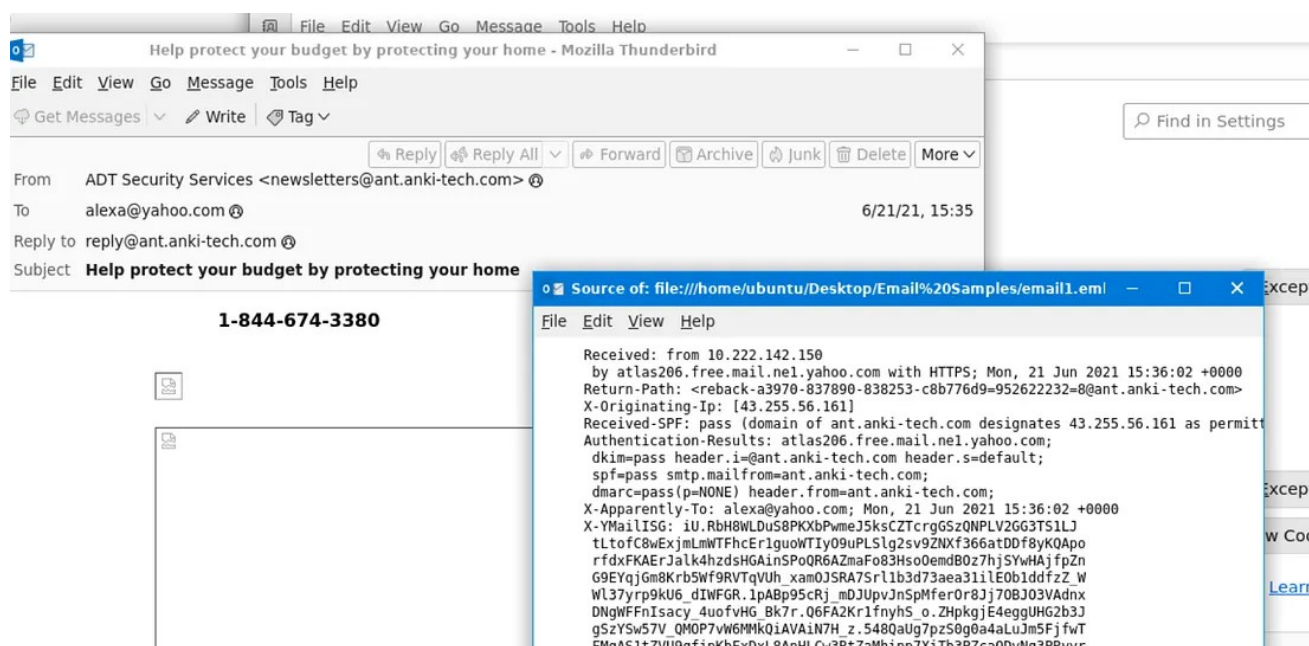
Let's take a look at the snippet of the raw message from the `email1.eml` file. You can see in the screenshot below that we have a wealth of information available to us for analysis, including the originating IP address and full email header details. Let's use this information to answer the task's questions below.



Email Headers

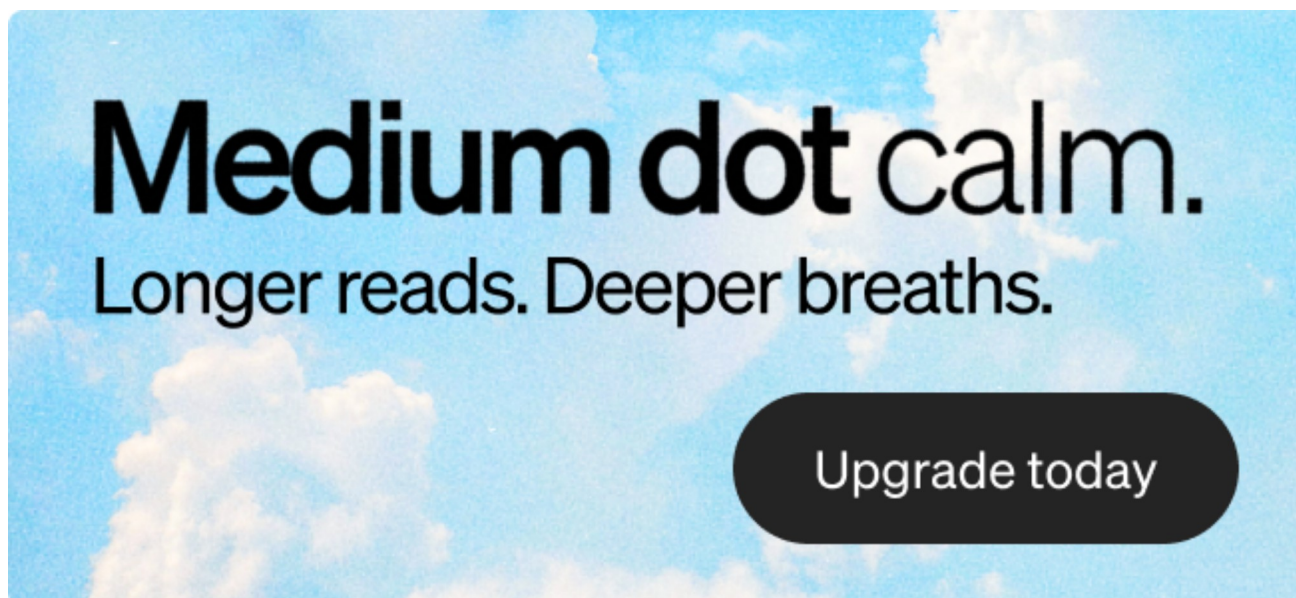


Viewing the Message Source



Viewing both of

Answer the questions below



Q 5- What is the full subject line of `email1.eml` ?

Answer : Help protect your budget by protecting your home

Q 6- View the message source of `email1.eml` using Thunderbird in your VM.

What the IP address listed as the `X-Originating-IP` ?

Answer :43.255.56.161

```
Return-Path: STEADY-85570-857050-858255-88877085-552022252-0@antenna-learn.com  
X-Originating-IP: [43.255.56.161]
```

X-Originating-IP address

Task 5- Email Body

As mentioned in the previous task, the body of an email contains the message. Emails are sent as text only or formatted in HTML. HTML supports elements such as images, links, and styling. Most email clients show you the rendered content. You can also inspect the underlying source to see how the message is structured, spot embedded elements, and look for signs of phishing or malicious content.

Hello Dave,

I hope you had a great holiday and weekend.

When you get a chance, could you please send over the Q1 finance report?

Thank you,

Steven - Accounting

Text Based Email

Cloud

URGENT: CLOUD ACCESS SUSPENDED

Access to your cloud services has been revoked. A failed billing verification caused an immediate suspension of critical cloud protections.

Accounts without active protection are exposed to **unauthorized access, data extraction, credential theft, and permanent data loss.**

HTML Formatted Email

Viewing HTML Source Code

Just as we can inspect an email's source to analyze its headers, we can also examine the source of the email body. This allows us to see the raw HTML that renders the message. Let's compare the rendered version of the `email1.eml` message with its underlying HTML. You may notice that some images are not displayed because Thunderbird blocks them by default. By viewing the raw source, we can clearly see how these HTML elements are structured behind the scenes, giving us a closer look at links, images, and other embedded content that may not be immediately visible in the rendered view.

The image shows a side-by-side comparison of an email's rendered view and its raw HTML source code. On the left, the 'Rendered HTML' view shows an email from 'ADT Security Services' with a subject 'Help protect your budget by protecting your home'. It features a large white rectangular area, likely a placeholder for an image, and a phone number '1-844-674-3380'. On the right, the 'Raw HTML' view shows the underlying code. Numbered callouts (1-5) link specific parts of the rendered email to their corresponding HTML code:

- 1: Links to the phone number '1-844-674-3380' in the subject line.
- 2: Links to the phone number '1-844-674-3380' in the body text.
- 3: Links to the phone number '1-844-674-3380' in the body text.
- 4: Links to the phone number '1-844-674-3380' in the body text.
- 5: Links to the phone number '1-844-674-3380' in the body text.

The raw HTML code includes various tags such as `<table>`, `<tr>`, `<td>`, `<img src=`, and `<a href=`, demonstrating the structure of the email body.

Reconstructing Attachments

Emails can also include attachments, such as documents, images, or other file types. Just as the email body can be analyzed by viewing the message source, attachments can be analyzed as well. This allows us to understand how the file is embedded within the email.

In the example below, you'll see an HTML-formatted email containing a PDF attachment. The rendered view shows the attachment as it appears in the email client, while the source view shows how it is actually stored within the message. When we inspect the source, we can identify several important headers associated with the attachment:

- **Content-Type** indicates the file type `application/pdf`
- **Content-Disposition** specifies that the file is an attachment and includes its filename
- **Content-Transfer-Encoding** shows that the file is `base64` encoded

The encoded base64 that follows represents the file itself. This data can be decoded to

The screenshot displays an email interface with two panels. The left panel, labeled 'Renderd HTML', shows a NetflixBot phishing email. The email body contains a dark grey box with white text: '-Your friends at Netflix', 'Questions? Call 007-803-321-2130', and a warning not to reply to the email. Below this is a PDF attachment icon labeled 'Payment-up-... .pdf' with a size of '150.7 KB'. The right panel, labeled 'Raw HTML', shows the email's source code. It highlights the following headers for the attachment: 'Content-Type: application/pdf; name="Payment-updated.pdf"', 'Content-Disposition: attachment; filename="Payment-updated.pdf"', and 'Content-Transfer-Encoding: base64'. Below these headers, the 'Content-ID' and 'X-Attachment-Id' are shown as 'f_km3inpm1l'. The main body of the email is a long base64-encoded string.

```
Content-Type: application/pdf; name="Payment-updated.pdf"
Content-Disposition: attachment; filename="Payment-updated.pdf"
Content-Transfer-Encoding: base64
Content-ID: <f_km3inpm1l>
X-Attachment-Id: f_km3inpm1l

JVBERi0xLjQKJcNlCW1tbW1DQoxlDAGb2JqDQo8PC9UeXBIL0NhdGFsb2cvUGFnZXMGMAwiFlvVGFu
Zyhbbl1VUykgL1N0cnVjdFRyZWUgMjAgMCBSCj4+CmVuZG9iagoxlDAGb2JqDQo8PC9QYXVldlcyAylDAG
Ui9Db3VudCAXPj4KZW5kb2JqCjMgMCBvYmoNCjw8L1R5cGUvUGFnZS9NZWRpYUJveFswlDAGNjEylDc5
Ml0vUGFyZW50lDlGMCBSCl9SZXNvdXJjZXMGPDwvRm9udCA8PC9GMSA0lDAGUj4+Pj4+Ci9Db250ZW50
cyA1lDAGUj4+CmVuZG9iagoxlDAGb2JqDQo8PC9UeXBIL0ZvbnQvU3VidHlwZS9UeXBIM59CYXNIrm9u
dC9lZWxz2ZXRpY2E+PgplbmRvYmoKNSAwIG9iagOKPDwvTGvUjZ3RoIDY2Pj4Kc3RyZWFlDQpCBlAwlDAG
VGQKKChQYXltZW50lHVwZGF0ZWQpKSBUagpFVAplbmRzdHJlYW0KZW5kb2Jq
```

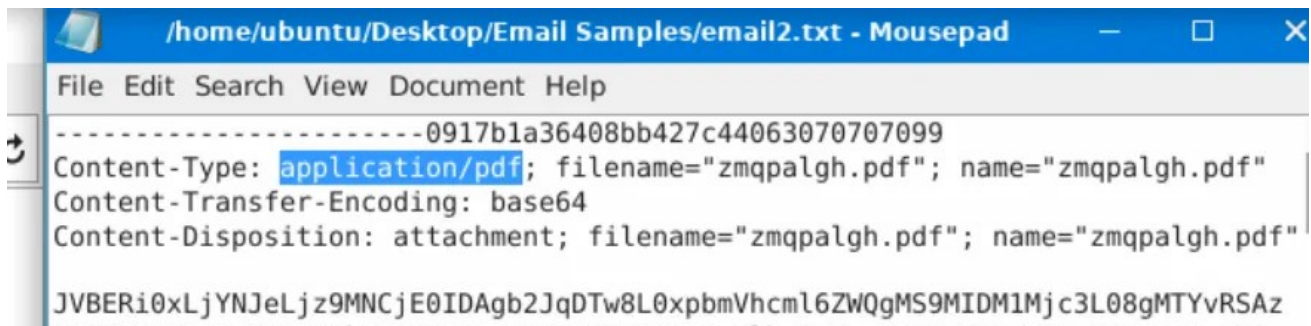
sample content

Answer the questions below

Q 7- Open up the `email2.txt` file to view the source of an attachment.

What is the `Content-Type` of the attachment?

Answer : `application/pdf`



```
-----0917b1a36408bb427c44063070707099
Content-Type: application/pdf; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"

JVBERi0xLjYNYeLjz9MNCjE0IDAgb2JqDTw8L0xpbmVhcml6ZWQgMS9MIDM1Mjc3L08gMTYvRSAz
```

Q 8- What is the name of the attachment from the previous question?

Answer : zmqpalgh.pdf

Q 9- Decode the base64 string using either a [PDF converter](#) or [CyberChef](#).
What is the hidden flag value?

Answer : THM{BENIGN_PDF_ATTACHMENT}

Task 6- Types Of Phishing

Now that we understand how emails are structured and delivered, it's important to recognize how attackers abuse this system. Email remains one of the most common entry points for cyber attacks, often relying on social engineering to trick users into taking action.

In this task, we'll explore the different types of malicious emails and the techniques attackers use to make them appear legitimate. By understanding these patterns, you'll be better equipped to identify suspicious messages and avoid common phishing traps before they compromise your systems. Different types of malicious emails can be classified as one of the following:

- Spam: Unsolicited bulk emails sent to a large number of recipients. A more malicious form of spam is often called malspam.
- Phishing: Emails that impersonate a trusted entity to trick recipients into revealing sensitive information.
- Spear Phishing: A targeted form of phishing aimed at a specific individual or organization, often using personalized information.

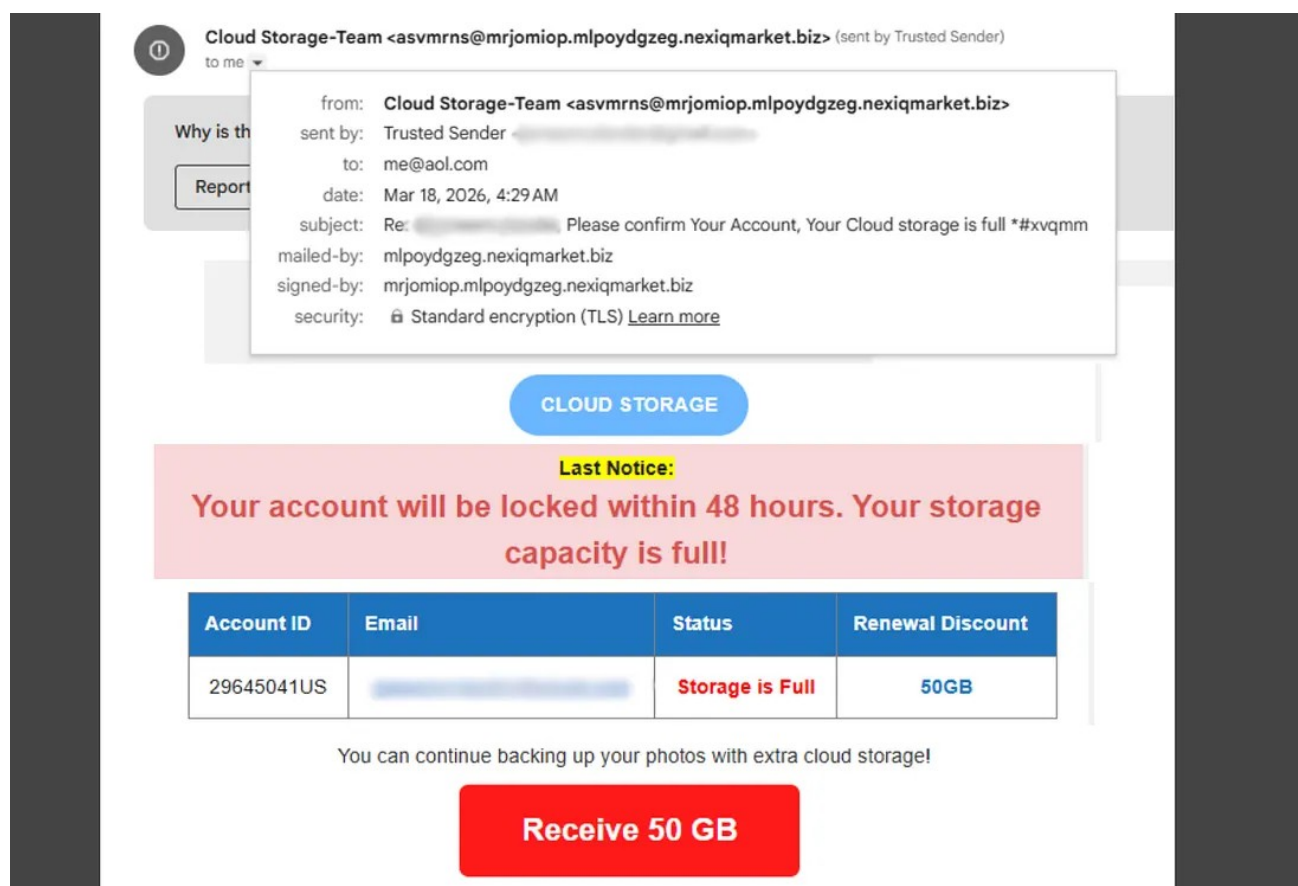
- **Whaling:** A type of spear phishing that specifically targets high-level executives (CEO, CFO) to obtain sensitive data or financial access.
- **Smishing:** Phishing attacks conducted via SMS or text messages, targeting users on mobile devices.
- **Vishing:** Phishing attacks carried out through voice calls, where attackers use social engineering over the phone.

Anatomy of a Phishing Email

When it comes to phishing, attackers often rely on similar techniques regardless of their goal. Their objective may be to harvest credentials, deliver malware, or gain unauthorized access to a system, but the methods used to trick the recipient are often the same.

Below are some common characteristics of phishing emails:

- **Spoofed From Address:** The sender's email is spoofed to appear as a trusted entity (`noreply@microsoft.com`)
- **Urgent Subject or Message:** The email creates a sense of urgency ("Your account will be locked in 24 hours")
- **Brand Impersonation:** The email is designed to mimic a legitimate organization (logos or colors matching a real company)
- **Grammar & Spelling Issues:** The message may contain errors, though with AI these are now less common (awkward phrasing or unnatural wording)
- **Generic Content:** The message lacks personalization ("Dear Customer" instead of your name)
- **Hidden or Shortened Links:** Hyperlinks may disguise their true destination (`bit.ly/secure-login`)
- **Malicious Attachments:** Attachments are included and disguised as legitimate files (`invoice.pdf.exe`)



Safe Analysis

When dealing with hyperlinks and attachments, be careful not to click them accidentally. Hyperlinks and IP addresses should be **defanged**. Defanging makes URLs, domains, or email addresses unclickable to prevent accidental clicks that could lead to a security breach. It works by replacing special characters, such as @ in an email or . in a URL, with alternate characters:

- Original URL: <http://www.suspiciousdomain.com>
- Defanged URL: `hxxp[:]//]www[.]suspiciousdomain[.]com`

Investigation

Let's put all of this knowledge to the test and analyze the email titled `email3.eml` within the virtual machine to answer the questions below.

Answer the questions below

Q 10- Which reputable organization is being spoofed in this phishing attempt?

Answer : Home depot

Q 11- What is the sender's email address?

Answer : support@teckbe.com

Q 12- Inspect the email message source.

What is the defanged X-Originating-IP ?

Answer : 103[.]234[.]236[.]83

Q 13 -Continue analyzing the email message source.

Which mail server generated the Authentication-Results header?

Answer : atlas102.free.mail.gq1.yahoo.com

```
Authentication-Results: atlas102.free.mail.gq1.yahoo.com;  
dkim=pass header.i=@teckbe.com header.s=dk2048;
```

Authentication-Results

Task 7- Conclusion

In this room, you explored the anatomy of an email, starting with the structure of an email address and the path a message takes from sender to recipient. You then developed the technical skills needed to investigate suspicious emails by extracting and analyzing both the header and body source code. Finally, you examined common phishing techniques and applied your knowledge to analyze real-world examples, identifying attacker intent. Nicely done!

Before moving on, it's also important to understand Business Email Compromise (BEC), a type of attack where an adversary gains access to a legitimate internal email account and uses it to trick others into performing unauthorized or fraudulent actions.

Further Learning

This room is the first of a series of rooms that make up the Phishing Analysis module of the SOC Level 1 Path. You are encouraged to continue your learning

with the walkthrough and challenge rooms below:

- [Phishing Emails in Action](#)
- [Phishing Analysis Tools](#)
- [Phishing Prevention](#)
- [The Greenholt Phish](#)
- [Snapped Phish-ing Line](#)

Answer the questions below

Q 14- What attack, signified by the acronym BEC, uses a compromised email to trick employees into fraud?

Answer :Business Email Compromise

happy hacking

Nuh hozar - Medium

Read writing from Nuh hozar on Medium. Whatever is in the name of goodness and beauty, those who know us know, those...

nuhhozar.medium.com

NuhHozar - Overview

Only Curiosity for cyber world. NuhHozar has 19 repositories available. Follow their code on GitHub.

github.com

<https://nuhhozar.blogspot.com/>

Phishing Analysis



Follow

Written by Nuh hozar

5 followers · 8 following

Whatever is in the name of goodness and beauty, those who know us know, those who don't know know as well as themselves.!!
